Controle Share Videos v2.7.0

Compartilhamento seguro de arquivos para uso interno restrito

Apresentação técnica para o Analista de TI

Funcionalidades · Gerenciamento de segurança · Conexões e infraestrutura

Em Produção (Docker) — Fork independente do Pingvin Share X v1.21.1

Agenda

1. O problema que o sistema resolve
2. Visão geral e stack tecnológica
3. Arquitetura de implantação
4. Funcionalidades principais
5. **Gerenciamento de segurança** (autenticação, sessões, perímetro, Docker)
6. **Mapa de conexões** (portas, protocolos, proteções)
7. Auditoria, monitoramento e observabilidade
8. Qualidade, CI/CD e operação
9. Status de auditoria e roadmap

1. O problema que o sistema resolve

Cenário: compartilhar vídeos/arquivos grandes internamente **sem nuvem externa** (soberania dos dados).

Dificuldades eliminadas:

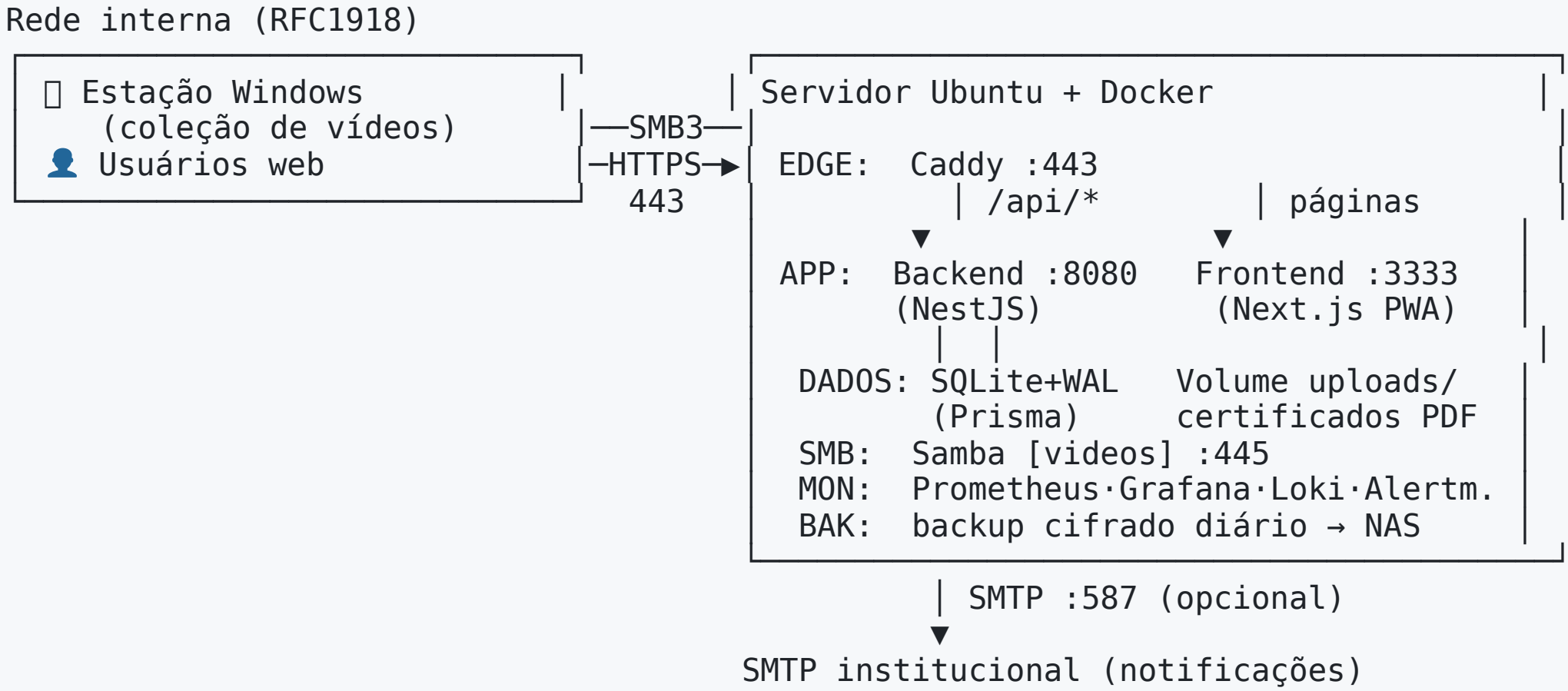
Antes	Com o sistema
Links públicos sem controle	Link com token opaco, senha, expiração
Sem rastreabilidade	Log completo: quem baixou, quando, IP, User-Agent
Pendrive/e-mail inseguro	Player exclusivo por link + download limitado
Sem expiração	Expiração automática configurável por share
Dados em nuvem terceira	Armazenamento **exclusivamente local** no servidor

> Uso interno restrito · interface 100% PT-BR · upload somente pelo dono autenticado

2. Stack tecnológica

Camada	Tecnologia
Frontend	Next.js 16 (React 19) + Mantine 9 — PWA offline-first (Serwist)
Backend	NestJS 11 (Node.js 24 + TypeScript) — API REST versionada `/api/v{N}`
Banco de dados	SQLite + WAL (Prisma ORM — queries 100% parametrizadas)
Reverse proxy / Edge	Caddy 2.9 — TLS automático (Let's Encrypt), CSP estrito, rate limit
Armazenamento	Local no servidor (sem S3) + compartilhamento Samba SMB3 `[videos]`
Containers	Docker Engine ≥ 24 + Compose v2, imagens pinadas por digest
Observabilidade	Prometheus, Alertmanager, Grafana, Loki + Promtail

3. Arquitetura de implantação (host on-premise)



- Backend em rede Docker `internal: true` — nunca exposto diretamente.
- Toda entrada pública passa pelo Caddy (único serviço publicado).

4. Funcionalidades — Compartilhamento

- **Link seguro** com token UUID v4 (opaco no servidor: `token_hash` + `revoked_at`)
- **Senha forte gerada automaticamente** pelo sistema (comprimento configurável)
- Controles por share:
  - Expiração configurável
  - Máximo de visualizações (`maxViews`) e downloads (`maxDownloads`)
  - Limite de visitantes
- **Limites enforced server-side em TODA via**: streaming inline e ZIP — token é revogado efetivamente ao esgotar qualquer limite
- Cada abertura do player = **1 view contada no servidor** (seeks via `Range` não contam — janela deslizante de 2 min)
- **Página exclusiva do destinatário** — sem header/footer do painel admin
- Destinatários por e-mail (SMTP opcional)

5. Funcionalidades — Upload e Certificado

Upload

- Somente pelo **dono autenticado** (reverse shares removidos intencionalmente)
- Upload **chunked multipart** com progresso e retomada
- Tamanho ilimitado (restrito só pelo disco) — limite editável no painel (`share.maxSize` + override por usuário)
- Validação: extensão + **magic bytes** + tamanho

Certificado de Autenticidade (automático)

- **1 PDF por vídeo** ao concluir o share: hash **SHA-256** (+ QR Code), metadados do arquivo/share/sistema, linha de eventos
- Datas em horário de Brasília (UTC-3), independente do fuso do servidor
- Vários vídeos → entrega em **zip único** preservando pastas/subpastas
- Metadados podem ser embutidos no vídeo via `ffmpeg -metadata`

6. Funcionalidades — Painel Admin e RBAC

Papéis (RBAC)

Papel	Permissões
admin	Gestão total: usuários, configurações, todos os shares, logs, relatórios, `/api/system/info`
operador	Upload e gestão dos **próprios** shares, histórico dos próprios downloads
auditor	**Somente leitura**: logs de download completos, auditoria de acessos

Recursos administrativos

- Usuários criados apenas pelo admin — **senha temporária forte (12 chars)** exibida uma única vez
- **Troca obrigatória de senha no primeiro login** (`passwordMustChange` + Guard)
- Dashboards: `/admin/download-logs`, `/admin/audit-logs`, `/admin/sessions`
- Saúde do sistema, sessões ativas, configurações persistidas no banco
- Cron jobs: limpeza de shares expirados, temporários, tokens, usuários não ativados

7. Segurança — Autenticação e sessões

Controle	Implementação
Senhas	**Argon2id** (memoryCost=128 MB, timeCost=4, parallelism=2)
Sessão	**Opaca server-side**: token 256-bit, **apenas SHA-256 persistido**, validação por requisição (revogado → expirado → usuário ativo → autorização)
Timeouts	**Idle 30 min + absoluta 8h** (atualização condicional de `last_activity_at`)
Refresh token	Persistido como hash, **rotação + detecção de reuso** (família inteira revogada)
MFA	**TOTP obrigatório para admins**, opcional para demais + **recovery codes** de uso único
Operações críticas	**Reautenticação recente** (troca de senha, e-mail, permissões, revogação)
CSRF	Double-submit token
JWT legado	Rotação híbrida (kid + timeline, AES-256-GCM, mutex) — inativo nas sessões atuais

8. Segurança — Tokens de compartilhamento



- Token **nunca armazenado em claro** — só o hash
- Revogação manual (bloqueio imediato) ou automática (limite/expiração)
- Guard revalida limites **a cada request** — anti-TOCTOU no download atômico

9. Segurança — Perímetro e headers

Caddy (Edge)

- **TLS automático** Let's Encrypt (renovação nativa); alternativa `tls internal` por IP
- **CSP estrito**: `default-src 'self'; script-src 'self'` (self-only)
- Filtro `pwd=` em query strings e logs
- Rate limit na borda: **dynamic 100 req/10s** geral, **10 req/60s** endpoints de auth

Headers aplicados

Header	Valor
Strict-Transport-Security	HSTS **preload**
X-Frame-Options	DENY
X-Content-Type-Options	nosniff
Cross-Origin-*	COOP + COEP + CORP
Permissions-Policy	Restritiva

10. Segurança — Rate limiting (3 camadas)

Camada	Regra	Escopo
Edge (Caddy)	100 req/10s (dynamic)	Todo o tráfego
Edge (Caddy)	10 req/60s	Endpoints de autenticação
App (global)	100 req/60s	API inteira
App (login)	5 tentativas/60s	Por conta **+ IP**
App (share token)	20/5min	Emissão de token do share
App (share/admin)	Limites específicos	Endpoints sensíveis

Resposta 429 com countdown lendo header `Retry-After` (UX honesta).

11. Segurança — Hardening Docker e host

Containers (100% itens críticos/altos implementados)

- **Non-root** (UID 1002) · `cap_drop: ALL` · `no-new-privileges:true`
- `read_only: true` + tmpfs para escrita · `pids_limit: 512`
- Backend em rede `internal: true` (sem saída)
- Imagens **pinadas por digest (SHA-256)** · Trivy no CI (CRITICAL/HIGH bloqueia)
- **Docker Secrets** em todos os serviços (backend, frontend, caddy, grafana)

Host Linux (spec dedicada `ESPECIFICACAO_SEGURANCA_DOCKER_HOST_v1.0.md`)

- UFW default-deny: libera **80/443**; SSH com `limit`; **SMB 445 só RFC1918**
- **fail2ban** para SSH + Samba
- seccomp custom **fail-closed** (428 syscalls bloqueadas)
- Docker Bench Security semanal · live-restore habilitado

12. Segurança — Auditoria à prova de adulteração

Trilha WORM tamper-evident

- Append-only NDJSON com **hash chain SHA-256**
- Verificação automática **diária** da integridade da cadeia
- Alerta crítico `AuditLogHashChainBroken` se a cadeia quebrar
- Endpoint de verificação: `/api/admin/audit-logs/chain-status`

Eventos registrados

- **DownloadLog**: view/download com IP, User-Agent, timestamp, sucesso/falha — inclui tentativas falhas
- **AuditLog**: 17 eventos mínimos — login, MFA, sessões, senha, permissões, shares (com IP/UA/requestId)
- **Revisão de acesso trimestral**: nível de risco por usuário + atestação assinada (HMAC) gravada no WORM

13. Mapa de conexões — portas e protocolos

Origem → Destino	Protocolo/Porta	Exposição	Proteção
Usuários → Caddy	**HTTPS :443** (:80 p/ ACME)	Pública	TLS Let's Encrypt auto, HSTS, CSP, rate limit
Estação Windows → Samba	**SMB3 :445**	Só LAN RFC1918	`encrypt required`, `signing mandatory`, full_audit VFS, veto de payload, fail2ban
Caddy → Frontend	HTTP :3333	Rede Docker interna	Não publicada no host
Caddy → Backend `/api/*`	HTTP :8080	Rede Docker interna	Rate limit edge, validação DTO
Backend → SQLite	Arquivo local + WAL	Container	Prisma parametrizado (zero `$queryRawUnsafe`)
Backend → Volume uploads	Bind mount `setgid 1002:1002`	Host	Container `read_only`
Backend → SMTP	**STARTTLS :587**	Saída opcional	Credenciais via Docker Secrets
Prometheus → Backend	GET `/api/metrics`	**Redes internas apenas**	Restrição por IP

14. Variantes de implantação (Compose)

Arquivo	Uso
`docker-compose.yml`	Produção padrão (backend + frontend + caddy; config via env/secrets)
`docker-compose.local.yml`	Teste local — container único, Swagger dev-only
`docker-compose.prod.yml`	Produção com Swarm secrets externos, dados em RAID6 (`/srv`)
`docker-compose.staging.yml`	Homologação
`docker-compose.monitoring.yml`	Observabilidade completa

Perfis do Caddyfile

`CADDYFILE`	Modo de acesso
`prod` (default)	Domínio + TLS Let's Encrypt
`ip`	Acesso por IP — HTTP `:80` ou `tls internal` `:443`
`local`	LAN/homologação sem TLS `:3000`

15. Monitoramento e observabilidade

- **Prometheus** coleta `/api/metrics` (restrito a redes internas)
- **33 regras de alerta** promtool-clean com roteamento:
  - Crítico → PagerDuty/Slack · Warning/Info → Slack
  - Inibições e tuning trimestral documentado (`docs/alert-tuning.md`)
- **Certificado TLS monitorado**: gauge de expiração exportado a cada 6h — alertas <30 dias e expirado
- **Loki + Promtail**: logs agregados centralizados
- **Grafana** dashboards sobre Prometheus + Loki
- Healthchecks: `/api/health` (público), `/api/system/info` (admin: disco, memória, versão, uptime)

16. Qualidade — Testes

Suíte	Conteúdo
Unit backend	**32 suites / 335 testes** (Jest), cobertura ≥ 60%
E2E backend	DB efêmero dedicado, não destrutivo
Frontend	Vitest unitários
Playwright	E2E de navegador
Security-E2E	Rate limiting, CSRF, senha de share, tokens opacos, bypass de limites (#40)
SQL Injection	Acesso 100% via Prisma parametrizado — zero `$queryRawUnsafe` (auditado 2026-08-22)

Pentest interno executado

- Black-box de links de compartilhamento (`PENTEST-SHARE-LINK-2026-08-22.md`)
- 1 achado HIGH corrigido (#40) · **11 controles aprovados**

17. CI/CD e supply chain

Security Gate (todo push)

Secret scanning (gitleaks) · hadolint · `npm audit` · **CodeQL** (JS+TS) · semgrep · Trivy · SBOM · production readiness check

Artefatos assinados

- **SBOM CycloneDX** assinado (cosign keyless)
- **Provenance SLSA Level 3** na release

Outros

- **OWASP ZAP baseline semanal** contra imagem de produção (falha em HIGH)
- Dependabot: npm dos 5 projetos + pins de actions (semanal)
- Todas as GitHub Actions **pinadas por SHA** (Node 24)
- Deploy produção **opt-in** via `DEPLOY_ENABLED` + SSH key

18. Operação — Backup e resposta a incidentes

Backup

- Diário: SQLite + uploads → 2º servidor/NAS, **cifrado**
- Bucket protegido: Object Versioning + MFA Delete + transição Glacier 90d + teste anti-deleção
- **Restore testado** periodicamente + drill de DR trimestral

Incidentes

- Runbooks de resposta a incidentes (`docs/operacional/RUNBOOKS.md`)
- Snapshot forense automatizado SEV-1 + chain of custody (`docs/forensics.md`)
- Postmortem sem culpa com template
- Rollback documentado (`docs/rollback-runbook.md`)

Atualização

```
git pull --ff-only origin main && docker compose up -d --build
# Migrações Prisma aplicadas automaticamente no boot
```

19. Status de auditoria

Item	Resultado
Auditoria geral	✅ 7.5/10 — aprovado para produção
Segurança (OWASP Top 10)	✅ **9.0/10**
Spec de sessões v1.2	✅ 17/17 correções (7 fases)
Hardening Fases 1–4	✅ 35/35 issues fechados com evidência
Pentest de share links	✅ Executado — HIGH corrigido, 11 controles OK
Checklist final	`docs/auditoria/CHECKLIST-SEGURANCA-FINAL.md`

Limitações conhecidas (monitoradas)

- SQLite: adequado até ~500 usuários simultâneos → migração PostgreSQL planejada se necessário
- Redis cache e storage S3/MinIO: prontos como interfaces, ativáveis sob demanda

20. Roadmap pós-v2.7

Versão	Foco	Itens principais
v1.1	Estabilização	Refatorações ✅, CSP ✅, Docker Secrets ✅, rate limit edge ✅
v1.2	SRE	Alertas ✅, distributed tracing (OpenTelemetry), chaos testing
v1.3	Escala	Redis opcional, PostgreSQL/MySQL se necessário
v1.4	Cloud	Storage S3/MinIO (interface já existe), multi-região
v2.0	Modernização	Avaliar Next.js App Router, NestJS 12+, Prisma 8+

21. Documentação de referência

Tema	Documento
Arquitetura	`docs/VISAO-GERAL.md` · `docs/DIAGRAMA-SISTEMA.md`
Implantação	`docs/operacional/DEPLOY.md` · `docs/HOST-PROVISIONING-ONPREMISE.md`
Segurança	`docs/ESPECIFICACAO-SEGURANCA.md` (v1.2) · spec hardening Docker/host
Auditoria	`CHECKLIST-SEGURANCA-FINAL.md` · pentests em `docs/auditoria/`
Conexões SMB	`docs/operacional/SAMBA-SEGURANCA.md`
Monitoramento	`docs/operacional/MONITORAMENTO.md` · `docs/alert-tuning.md`
Operação	`BACKUP_RESTORE.md` · `RUNBOOKS.md` · `GOLIVE-CHECKLIST.md`
Certificado	`docs/CERTIFICADO.md`

Obrigado!

Controle Share Videos v2.7.0

Compartilhamento seguro · dados soberanos on-premise

Dúvidas técnicas: consultar `README.md` e `docs/VISAO-GERAL.md`